1. Authentication Bypass via SQL Injection (Broken Authentication)

This vulnerability is focused on manipulating the login fields to gain unauthorized access.

Component	Rating	Justification
Risk Rating	**High**	Allows an attacker to gain administrative or privileged access to user accounts without a valid password, leading to full data compromise and unauthorized actions.
Remediation	**Prepared Statements & Hashing:** The application must use **Parameterized Queries** (Prepared Statements) for all database :interactions involving user input (username, password). Passwords must never be stored in plain text; they should be stored as strong **hashes** (e.g., using bcrypt or Argon2).	

2. General SQL Injection (Reflected / Parameter)

This task focuses on injecting SQL payloads into search boxes or URL parameters (e.g., `id` parameter).

Component	Rating	Justification
Risk Rating	**High**	Allows the attacker to retrieve sensitive data from the database, or potentially modify/delete data, depending on the application's configuration.
Remediation	**Parameterized Queries & Input Validation:** Use parameterized queries for all database queries. Additionally, enforce strict **input validation** and **sanitization** to ensure that data types are correct (e.g., ensuring an `id` field only accepts an integer).	

3. Cross-Site Scripting (XSS)

This vulnerability occurs when the application accepts and reflects malicious script input (e.g., `<script>alert(1)</script>`) without proper encoding.

Component	Rating	Justification
Risk Rating	**Medium**	An attacker can steal session cookies, impersonate users, redirect clients to malicious sites, or deface the application's interface.
Remediation	**Output Encoding:** All user-supplied data must be **encoded**(escaped) before being rendered back to the user's browser. For example, convert < to `<` and > to `>` to prevent the browser from executing the code.	

4. Session Management Flaws & Cookie Manipulation

This involves weaknesses in how session IDs or cookies are managed, allowing an attacker to hijack a valid session.

Component	Rating	Justification
Risk Rating	**Medium**	If session tokens are predictable or lack proper expiration, an attacker can steal or guess a valid token to hijack another user's active session.
Remediation	**Secure Cookies & Expiration:** Implement secure cookie flags such as **`HttpOnly`** (to prevent client-side script access, mitigating XSS impact) and **`Secure`** (to ensure cookies are sent over HTTPS only). Furthermore, enforce a short and reasonable **session expiration time**.	